- **Image & Video (Img2Vid, Vid2Vid, Txt2Vid):** Transformasi visual kini jauh lebih stabil mempertahankan struktur asli objek. Dalam produksi video vertikal 9:16 misalnya, fitur *Video-to-Video* memungkinkan Anda memasukkan *raw footage* berbasis *green screen* sambil mempertahankan ekspresi wajah subjek secara mulus, lalu menyuntikkan *color grading* sekelas *Dark Golden Hour cinematic Japanese aesthetic* untuk menonjolkan *deep teal shadows* dan *warm amber highlights*.

- **All-in-One Engine:** Model *frontier* seperti Argon pada dasarnya dirancang sebagai otak sentral *multimodal*—Anda bisa memasukkan *screenshot* referensi warna, *file* audio referensi, dan

dokumen teks skenario secara bersamaan untuk dianalisis menjadi satu draf perencanaan tanpa perlu berpindah-pindah platform.

DOKUMEN MASTER BLUEPRINT (END-TO-END): EKOSISTEM OTONOM bikinAI Super Intelligence

Dokumen ini merangkum secara utuh seluruh arsitektur teknis, model bisnis agregator, perhitungan biaya operasional 24/7, bedah psikologi kompetitor, otomatisasi multi-agen, hingga rekayasa pertahanan siber tingkat lanjut (*Red-Teaming & Zero-Knowledge Security*) untuk membangun dan mengembangkan **bikinAI Super Intelligence** dari titik modal Rp 0 hingga skala komersial global.

BAGIAN I: VISI EKOSISTEM & ARSITEKTUR END-TO-END

Kekuatan utama bisnis agregator AI bukanlah menciptakan model dari nol, melainkan **orkestrasi dan efisiensi biaya (arbitrase API & GPU)**: membeli komputasi secara grosir/detikan atau memanfaatkan celah *free-tier* resmi, lalu menjualnya secara eceran lewat antarmuka yang sangat mudah diakses. Kunci agar biaya harian tidak membengkak saat sistem berjalan 24 jam penuh adalah **memisahkan "Kantor Resepsionis" (yang harus menyala 24 jam namun sangat ringan) dari "Pabrik Render GPU" (yang hanya menyala saat ada pesanan masuk)**.

1.1 Bedah Komponen Dasar Arsitektur (End-to-End)

1. **Telegram Bot (Etalase, Kasir, & Remote Control):** Berfungsi sebagai *front-end* tempat pengguna mengetik perintah (misalnya /buat_video atau /buat_kampanye 'Promo Diskon Akhir Tahun'), mengecek saldo kredit, dan membayar lewat QRIS atau pembayaran global. Dibangun menggunakan *library* gratis Aiogram (Python) atau Telegraf (Node.js).
2. **Agentic AI / Muse / Orchestrator (Otak & Project Manager Mandiri):** Berperan sebagai *Project Manager Mandiri* yang menerima perintah besar dari Telegram, membuat *roadmap*, dan membaginya menjadi subtugas otomatis (Tugas A: Tulis naskah, Tugas B: Bikin prompt visual, Tugas C: Bikin gambar/video). Dibangun menggunakan modul **Python Async Agent** mandiri yang bebas dari batas pemakaian personal, atau kerangka kerja *open-source* seperti **Hermes Agent** / **LangGraph**.
3. **9Router & OpenRouter (Manajer Distribusi & Penyelamat Token):**
    - **9Router (decolua/9router):** Berjalan di *localhost* server (http://localhost:20128/v1) sebagai pengatur dan pemilah permintaan dari Muse ke API AI. Memiliki fitur kompresi token (*RTK & Caveman*) yang menghemat pemakaian token 20%–65%, serta **3-Tier Fallback Otomatis**. Jika satu AI habis kuota, otomatis bergeser (*fallback*) ke AI alternatif/gratis (seperti *Kiro AI Free*, *OpenCode Free*, *Gemini API Free Tier*, *Qwen*, *Llama*, atau *NVIDIA NIM*) tanpa *error*.
    - **OpenRouter:** Dipasang di dalam 9Router sebagai cadangan (*Tier-2/Tier-3*) yang menyediakan puluhan model berlabel :free (Llama 3.3, Qwen 2.5, DeepSeek R1/V3) serta model berbiaya sangat murah ($0,05$–0,20 per 1 juta token).

4. **Infrastruktur / Server 24 Jam (VPS / Oracle Cloud / PythonAnywhere):** Tempat menjalankan kode Bot, database pengguna, dan 9Router secara non-stop 24 jam di *background* tanpa mengandalkan Google Colab yang sering terputus.
    - *Catatan Teknis PythonAnywhere vs. Oracle Cloud:* Akun gratis PythonAnywhere memblokir koneksi keluar (*outbound*) ke API di luar *whitelist* dan membatasi proses Node.js (9Router). Untuk server 24 jam bermodal **Rp 0 selamanya**, gunakan **Oracle Cloud Free Tier (Ampere A1 ARM: 2–4 OCPU & 12–24 GB RAM gratis selamanya + 2 VM AMD Micro)** dengan trik *upgrade* ke status **Pay-As-You-Go (PAYG)** (tagihan tetap Rp 0 selama di dalam batas gratis, bebas *error Out of Capacity*, dan anti-suspend), atau gunakan VPS Linux Ubuntu murah seharga Rp 20.000–Rp 25.000/bulan.
5. **Vast.ai / RunPod / API Grosir (Pabrik Render Video & Gambar):** Menyewa GPU (minimal **24 GB VRAM** seperti NVIDIA RTX 3090 atau RTX 4090) untuk menjalankan **ComfyUI API** (model *open-source Wan 2.1/2.2*, *HunyuanVideo*, *LTX-Video*, *Flux*) dengan sistem **On-Demand / Auto-Start & Stop** atau **Serverless**. Untuk model komersial tertutup (*Kling AI*, *Google Veo*, *Runway*, *Sora*, *Suno*), sistem menembak API grosir *Pay-Per-Call* (*Fal.ai*, *Replicate*, *Novita AI*, *PiAPI*) tanpa biaya sewa GPU per jam.

1.2 Spesifikasi 5 Agentic AI dalam Ekosistem bikinAI Super Intelligence

Sistem dirancang ramping menggunakan **5 Agentic AI (1 Koordinator + 3 Pekerja Spesialis + 1 Agen CS Otomatis)**:

Nama Agen	Peran dalam Sistem	Model AI (via 9Router / OpenRouter)	Biaya Modal
1. Gatekeeper & Billing Agent	Mengecek saldo koin user secara atomik, memvalidasi keamanan prompt (anti-spam/CSAM), mendeteksi bahasa pengguna (language_code), dan memotong kuota otomatis setelah pembayaran sukses.	Script Python murni + LLM ringan (Qwen / Gemini Flash Free)	**Rp 0**
2. Orchestrator Agent (Muse/PM)	Menerima perintah kasar dari user di Telegram/WA/FB, lalu memecahnya menjadi *roadmap* subtugas JSON (Naskah, Prompt Visual, Audio/Video).	Claude Sonnet (via Kiro Free di 9Router) / DeepSeek	**Rp 0**
3. Prompt Engineer & Sanitizer Agent	Mengubah bahasa daerah/Indonesia/asing pendek dari user menjadi *prompt* bahasa	Gemini Flash / Llama 3.3 70B (:free di OpenRouter) / Hermes 3 (jalur Unfiltered)	**Rp 0**

Nama Agen	Peran dalam Sistem	Model AI (via 9Router / OpenRouter)	Biaya Modal
	Inggris sinematik lengkap dengan *camera movement* dan *lighting*, serta melakukan *Auto-Rewrite* agar aman bagi API hulu.		
4. Media Worker & Compiler Agent	Mengirim JSON *workflow* ke API ComfyUI di Vast.ai/RunPod atau Fal.ai, memantau antrean *render* (*polling*), menjahit klip panjang dengan **FFmpeg**, lalu mengirim hasil akhirnya kembali ke pengguna.	Script Python Async + Webhook + FFmpeg	**Rp 0** *(di luar sewa GPU)*
5. AI Support & Triage Agent (CS 24 Jam)	Melayani komplain pribadi pelanggan, mengecek status Job_ID yang gagal secara *read-only* di database, memproses *auto-refund* jika terbukti *timeout*, membaca bukti transfer dengan Vision AI, dan mengirim tombol eskalasi 1-klik ke Admin.	Gemini Flash Free / Qwen 2.5 72B (via 9Router)	**Rp 0**

1.3 Kebijakan Mutlak: 100% Legal & Open-Source (Surface Web)

Seluruh fondasi teknologi berdiri 100% di atas ekosistem *open-source* resmi dan *free-tier* legal di *Surface Web* (GitHub, HuggingFace, Civitai, Google AI Studio, OpenRouter, Groq, NVIDIA NIM, Cloudflare). Penggunaan sumber dari *dark web* dihapus dan dieliminasi sepenuhnya karena membawa risiko **Malware Stealer** (pencurian sesi Telegram dan pembelokan *webhook* pembayaran QRIS) serta **Downtime Mendadak** akibat akun/API curian yang mati dalam hitungan jam.

1.4 Strategi Omnichannel "1 Otak, 3 Pintu" (Telegram, Facebook, WhatsApp)

Untuk menjangkau seluruh lapisan pengguna tanpa biaya pembuatan aplikasi Android/iOS dari nol, sistem menggunakan arsitektur **Omnichannel Webhook (1 Server Otak Pusat, 3 Pintu Masuk)** dengan 1 saldo koin yang terhubung lintas platform:

Platform	Cara Integrasi Gratis (Rp 0)	Keunggulan Strategis untuk Bisnis Anda
1. Telegram Bot	Daftar resmi di **BotFather** (100% Gratis selamanya, tanpa batas pesan).	**Markas Utama (Fitur Terlengkap):** Mendukung menu tombol berlapis, kirim file video besar (hingga 2GB), grup komunitas *Forum Topics*, dan tampilan *Mini App*.
2. Facebook Messenger	Gunakan **Meta for Developers (Messenger API Resmi)** yang dihubungkan ke *Facebook Page* bisnis Anda (100% Gratis).	**Mesin Akuisisi Pelanggan Viral:** Saat Anda *posting* contoh video AI di Facebook, pasang fitur *Auto-Reply Comment*. Begitu ada orang berkomentar *"Mau coba"*, bot otomatis mengirim pesan ke inbox Messenger mereka dan langsung melayani pembuatan gambar/video di sana.
3. WhatsApp (WA)	• **Opsi A (Resmi):** *Meta WhatsApp Cloud API* memberikan kuota gratis untuk membalas pesan masuk (*Service Conversations* dalam jendela 24 jam). • **Opsi B (Open-Source Mandiri):** Pasang **WAHA (WhatsApp HTTP API)** atau **Baileys** di VPS Anda (Rp 0, cukup *scan* QR dari nomor WA khusus bot).	**Pasar Paling Luas:** Menjangkau pengguna awam/UMKM yang belum punya Telegram. Mereka cukup simpan nomor WA bot Anda dan kirim pesan seperti *chatting* biasa.

BAGIAN II: FINANSIAL, HITUNGAN BIAYA OPERASIONAL 24/7, & SIMULASI KEUNTUNGAN

2.1 Tabel Biaya Tetap Bulanan (Base Infrastructure 24/7)

Biaya untuk membiarkan "Toko Utama" (Bot Telegram/WA/FB + 9Router + 5 Agentic AI + Database) menyala **24 jam sehari selama 30 hari penuh**:

Komponen	Skema 1: Gerilya (Modal Rp 0)	Skema 2: Stabil (Modal Minim)	Keterangan
Server Bot & 9Router (24 Jam)	**Rp 0** (Oracle Cloud Free / GCP Micro / Meta Muse VM)	**Rp 25.000 / bln** (VPS KVM 1–2GB RAM lokal/NatVPS)	Biaya harian Skema 2 cuma **~Rp 833 / hari**.
Telegram / FB / WA Bot API	**Rp 0**	**Rp 0**	Gratis penuh.
LLM / Teks / Prompt (9Router)	**Rp 0** (Combo Full-Free: Kiro + Gemini + Groq +	**Rp 16.000 / bln** ($1 saldo cadangan	9Router memeras yang gratis dulu (98% limit),

Komponen	Skema 1: Gerilya (Modal Rp 0)	Skema 2: Stabil (Modal Minim)	Keterangan
	OpenRouter Free)	OpenRouter/DeepSeek)	saldo $1 hanya untuk darurat.
Database & Storage Media	**Rp 0** (SQLite WAL lokal + Cloudflare R2 Free 10 GB/bln)	**Rp 0** (SQLite WAL + Cloudflare R2 Free 10 GB/bln + Auto-Delete 24 Jam)	Bebas biaya *bandwidth egress* di Cloudflare R2.
TOTAL BIAYA TETAP / BULAN	**Rp 0 / bulan**	**Rp 41.000 / bulan**	**Biaya jalan 24 jam: Rp 0 s/d Rp 1.366 per hari!**

2.2 Hitungan Biaya Variabel Pabrik Render GPU (HPP per Generate)

- **Sewa GPU RTX 3090 / RTX 4090 (24 GB VRAM) di Vast.ai / RunPod: $0,20 – $0,38 per jam** (**Rp 3.200 – Rp 6.000 per jam**).
- **Waktu Render 1 Video AI (5 detik, model *Wan 2.1/2.2* atau *LTX-Video* dengan optimasi *TeaCache / SageAttention* di ComfyUI): 40 hingga 60 detik** (1 jam GPU menyala menghasilkan **45–60 video**).
- **Modal HPP Murni per 1 Video (Saat Antrean Padat):** Rp 5.800 \div 45 video = **Rp 128 per video**.
- **Modal HPP Rata-Rata per 1 Video (Termasuk Jeda *Booting/Idle*): Rp 300 – Rp 500 per video**.
- **Modal HPP per 1 Gambar HD (*Flux Schnell / Dev*):** Butuh 3–5 detik = **Rp 15 – Rp 30 per gambar** (atau **Rp 0** via *Cloudflare Workers AI* / *Pollinations* / *HuggingFace Free*).

2.3 Sistem Ekonomi Koin, Paket Top-Up QRIS, & Pembayaran Global

Untuk menghindari potongan biaya tetap transaksi mikro pada QRIS (MDR ~0,7%) dan mempermudah transaksi lintas negara, sistem menggunakan mata uang internal **Koin (1 Koin = Rp 100)**:

- **Pilihan Paket Top-Up QRIS Otomatis (Pasar Indonesia):**
  - **Paket Coba-Coba: Rp 5.000** (50 Koin = cukup untuk 2 video + 2 gambar HD).
  - **Paket Kreator: Rp 15.000** (160 Koin = gratis bonus 10 Koin, jatuh di harga Rp 1.875/video).
  - **Paket Agensi: Rp 50.000** (600 Koin = gratis bonus 100 Koin, jatuh di harga Rp 1.666/video).
- **Pilihan Pembayaran Pasar Global (Otomatis Muncul bagi User Non-Indonesia):**
  1. **Telegram Stars (⭐ Pay with Stars):** Mendukung Apple Pay, Google Pay, dan Kartu Kredit internasional langsung di dalam Telegram, dicairkan menjadi USDT/TON via Fragment.
  2. **Crypto / USDT Instant (@CryptoBot / NOWPayments):** Pembayaran kripto otomatis dengan konfirmasi instan.

2.4 Tabel Sistem 3 Kasta Model (3-Tier Pricing) & Variasi Durasi Video

A. Tabel 3 Kasta Layanan bikinAI Super Intelligence

Kasta / Tier	Pilihan Engine AI di Dalamnya	Harga ke User (Koin / Rupiah)	Modal Anda (HPP)	Margin Laba
🟢 **TIER ECO** *(Gratis / Pemancing)*	• **Chat, Coding & Baca PDF:** Gemini Flash, Qwen 2.5, Llama 3.3, DeepSeek (via 9Router) • **Gambar Draft:** Flux Schnell	**0 Koin (Gratis)** *(30 chat/hari, atau Unlimited bagi yang pernah top-up)*	**Rp 0**	Penarik trafik & *user retention*
🔵 **TIER PRO** *(Andalan Margin Tebal)*	• **Otak Kampanye:** Muse + Claude (via 9Router) • **Gambar HD & Upscale 4K:** Flux.1 Dev / Real-ESRGAN • **Video AI:** Wan 2.1 / 2.2 (T2V, I2V, Motion VACE), LTX-Video, Hunyuan (via GPU Vast.ai / RunPod)	• **Gambar HD / Upscale:** 4–5 Koin (Rp 400–500) • **Video 5 dtk:** 20 Koin (Rp 2.000) • **Paket Kampanye Utuh:** 25 Koin (Rp 2.500)	• Gambar: ~Rp 0–25 • Video: ~Rp 300–500 • Kampanye: ~Rp 350	**~80% – 85%**
🟣 **TIER ULTRA** *(Model Komersial Flagship)*	• **Video Flagship & Motion:** Kling 1.6/2.6/3.0 (Std & Pro), Seedance, Google Veo, Sora, Runway • **Musik Studio:** Suno v4/v6 Studio & Udio • **Chat Flagship:** Claude Sonnet/Opus Resmi	• **Musik Suno:** 15 Koin (Rp 1.500) • **Video Flagship:** 25–50 Koin (Rp 2.500 – Rp 5.000) • **Chat Flagship:** 2 Koin (Rp 200)	Ditembak via API *pay-per-use* (Fal.ai / Replicate / Novita / PiAPI) tanpa sewa GPU per jam. Modal Video: ~Rp 1.500–2.500	**~45% – 50%** *(0% Risiko GPU Menganggur!)*

B. Tabel Harga Jual Video Berdasarkan Durasi (Solusi Atas Kelemahan Kompetitor)

Di grup kompetitor, pengguna mengeluhkan tidak bisa membuat video *Text-to-Video* berdurasi 30 detik. Di sistem kita, **Muse** otomatis memecah naskah 30 detik menjadi **6 adegan \times 5 detik**, merendernya di GPU, lalu menggabungkannya secara otomatis dengan **FFmpeg** beserta musik/narasi suara menjadi 1 video utuh:

Jenis Layanan Video	Durasi	Harga ke User (Koin / Rupiah)	Modal GPU Anda (HPP)	Keuntungan Bersih
Video Klip Standar	5 Detik	**20 Koin (Rp 2.000)**	~Rp 200 – Rp 350	**~Rp 1.650 / video**

Jenis Layanan Video	Durasi	Harga ke User (Koin / Rupiah)	Modal GPU Anda (HPP)	Keuntungan Bersih
(720p/1080p)				
Video Klip Panjang / HD	10 Detik	**35 Koin (Rp 3.500)**	~Rp 500 – Rp 700	**~Rp 2.800 / video**
Paket Story / Iklan Utuh *(6 Klip + Jahit FFmpeg + Voiceover/Musik)*	30 Detik	**100 Koin (Rp 10.000)**	~Rp 1.800 – Rp 2.200	**~Rp 7.800 / video**

2.5 Tabel Simulasi Prediksi Keuntungan Bulanan

Asumsi menggunakan **Skema Stabil** (Biaya tetap VPS + cadangan LLM = Rp 41.000/bulan), harga jual rata-rata **Rp 2.000/video**, dan HPP GPU rata-rata **Rp 350/video**:

Skala Trafik Harian	Total Video / Bulan	Omzet Kotor (Rp 2.000/video)	Biaya Server 24 Jam + LLM	Biaya GPU (Vast.ai / RunPod)	Potongan QRIS (~0,7%)	**Laba Bersih / Bulan**
Sepi (10 video/hari)	300 video	Rp 600.000	Rp 41.000	Rp 105.000	Rp 4.200	**Rp 449.800**
Sedang (50 video/hari)	1.500 video	Rp 3.000.000	Rp 41.000	Rp 525.000	Rp 21.000	**Rp 2.413.000**
Ramai (200 video/hari)	6.000 video	Rp 12.000.000	Rp 75.000 *(upgrade VPS)*	Rp 1.800.000 *(semakin hemat krn antrean padat)*	Rp 84.000	**Rp 10.041.000**

BAGIAN III: STRATEGI AKUISISI PASAR, BEDAH KOMPETITOR, & RETENSI PENGGUNA

3.1 5 Alasan Pengguna Pindah dari Aplikasi Gratis (Gemini/Dola) & Rela Membayar di Bot Kita

1. **Super-App Satu Pintu Tanpa Pindah Aplikasi:** Pengguna tidak perlu menginstal 5 aplikasi berbeda yang memakan memori HP; chat, baca PDF, buat gambar, musik Suno, hingga video selesai di dalam Telegram/WA/FB mereka.
2. **Eksekusi "1 Perintah Jadi Paket Kampanye Utuh" (Muse Orchestrator):** Cukup ketik 1 kalimat perintah, Muse langsung menghasilkan Naskah Copywriting + Prompt Visual + Poster + Video sekaligus.
3. **Bayar Eceran (Pay-As-You-Go) Rp 2.000 via QRIS:** Aplikasi resmi membatasi kuota video harian dan mengharuskan langganan Rp 320.000/bulan ($20) dengan kartu kredit. Di bikinAI, pengguna bisa beli eceran Rp 2.000–Rp 5.000 kapan saja lewat QRIS.
4. **Preset Lokal & Komersial Siap Klik:** Tombol siap pakai seperti *"Video Affiliate TikTok"*, *"Foto Produk UMKM Jadi Studio Mewah"*, dan *"Motion Control Dance"*.
5. Efek Viral Watermark Gratis: Hasil *generate* dari koin klaim harian gratis menyertakan *watermark* halus @bikinAI_bot di sudut video, menjadi iklan gratis setiap kali dibagikan

pengguna ke media sosial.

3.2 Teknik "98% Quota Surfing" & "Max-Depth Output" di Dapur 9Router

Agar fitur **Chat 0 Koin** dan otak **Muse** selalu bertenaga maksimal tanpa terkena *cut-off* atau memboroskan modal:

1. **98% Quota Surfing:** Sistem menghitung pemakaian *request* dan token tiap API Key secara *real-time*. Jika batas gratis sebuah kunci API adalah 1.000 *request*, sistem memerasnya hingga angka **980 (98%)**, lalu otomatis memindahkan jalur ke API Key berikutnya tepat sebelum menyentuh *Error 429*.
2. **Max-Depth Output (Auto-Continue Chaining):** Mengatur batas *output token* di titik tertinggi yang aman dan otomatis menyambung potongan jawaban di balik layar sebelum dikirim ke pengguna.
3. **Smart Context Compression:** Merangkum obrolan lama menjadi memori padat sehingga >90% jatah token selalu fokus dipakai untuk memikirkan jawaban baru.

3.3 Bedah Rahasia Dapur Kompetitor (PosBot / PosMotion) dari Bukti Lapangan

Berdasarkan tangkapan layar komunitas kompetitor (PosBot Sharing Area), berikut adalah mekanisme mereka yang kita adopsi dan sempurnakan:

1. **1 Supergroup dengan Fitur "Forum Topics":** Kompetitor menggunakan 1 grup Telegram yang diaktifkan fitur *Topics*-nya (📈 Activity Bot, ⁉️ Laporan Error, 💰 Lapak, 🎉 Welcome Area, 🟠 Saran & Masukan, ☕ Ngopi Sopan, 🤖 Creative Assistance, 📣 Pengumuman BOT, 💡 Belajar & Sharing Karya, 📚 Tutorial).
2. **Mesin FOMO di Topik 📈 Activity Bot:** Setiap kali ada pembuatan media yang selesai, bot otomatis mengirim laporan teks ke topik Activity Bot yang dikunci: menyensor sebagian username (Kreator: @M***k, @I***9), menampilkan model yang dipakai (BetaGrok 1.5 1080p (15s), Suno v6 Studio, BetaMotion 1080p (30s)), menyensor harga (Biaya: Rp •••••), dan menampilkan penghitung total (🏆 Generate sukses ke-29.560) **tanpa melampirkan file medianya** agar grup 100% aman dari pemindai NSFW Telegram.
3. **Struktur Harga & Saldo Pancingan Kompetitor:** Kompetitor memberikan saldo awal Rp 500 dan mematok harga Kling MC 2.6 Std (5s) Rp 2.000, Kling MC 2.6 Pro (5s) Rp 2.700, Kling MC 3.0 Std (5s) Rp 3.000, hingga Kling MC 3.0 Pro (5s) Rp 3.500.

3.4 Sistem Cerdas "Daily Credit Claim" & Proteksi 2 Dompet (Anti-Tuyul)

Untuk menerapkan efek psikologis *Endowed Progress Effect* seperti saldo Rp 500 milik kompetitor tanpa bisa dicurangi oleh penambang akun palsu (*tuyul*):

1. **Klaim Harian Rp 400 (4 Koin Bonus) per Hari:**
    - Di hari pertama klaim, 4 Koin tersebut **langsung cukup** untuk membuat **1 Gambar AI HD (Flux)** atau **1x Upscale Foto 4K** (yang modal HPP aslinya bagi kita hanya Rp 0–Rp 20).
    - Untuk membuat **Video AI (20 Koin / Rp 2.000)**, pengguna bisa memilih **Jalur**

Sabar (absen klaim 5 hari berturut-turut di Mini App) atau **Jalur Cepat** (langsung *Top-Up* QRIS Rp 5.000 karena merasa sudah punya tabungan awal).

2. **Sistem 2 Dompet Terpisah (koin_utama vs. koin_bonus):**
    - 🟢 **Koin Bonus (Hasil Klaim Harian & Referral Pendaftaran):** Bebas dipakai 100% untuk fitur yang HPP-nya mendekati Rp 0 (Gambar Standar/HD, Upscale, Asisten Teks). Untuk fitur yang membakar saldo API/GPU mahal (Video Flagship/Suno), Koin Bonus baru terbuka *full* jika akun tersebut **sudah pernah melakukan Top-Up minimal 1 kali (Rp 5.000)** seumur hidup sebagai verifikasi manusia asli, atau berfungsi sebagai potongan diskon Rp 500 per video.
3. **Mesin Pertumbuhan Grup Otomatis:** Tombol [🎁 Klaim Kredit Harian] mewajibkan pengguna sudah tergabung di dalam **Grup Komunitas bikinAI** (dicek otomatis lewat fungsi getChatMember Telegram API).

3.5 Program Affiliate Gratis (2 Jalur Sekaligus — Modal Rp 0)

1. **In-Bot Referral (database.py):** Setiap pengguna mendapat tautan https://t.me/bikinAI_bot?start=ref_USERID. Pengundang mendapat **+2 Koin Bonus** saat teman bergabung ke grup, ditambah **Komisi 10%–15% Koin Utama Seumur Hidup** setiap kali teman tersebut melakukan *Top-Up* QRIS/Stars.
2. **Telegram Official Affiliate Program (@BotFather):** Mengaktifkan fitur afiliasi resmi Telegram dengan bagi hasil 15%–20% *Telegram Stars*, sehingga ribuan pemilik channel global ikut mempromosikan bot Anda secara otomatis.

3.6 Sistem Cerdas Multi-Bahasa Global (Auto-Localization)

- **Deteksi Bahasa Otomatis (message.from_user.language_code):** Jika bahasa HP pengguna adalah id, bot menampilkan antarmuka Bahasa Indonesia & pembayaran QRIS. Jika selain id, bot otomatis menyajikan antarmuka **Bahasa Inggris Internasional** & pembayaran **Telegram Stars / Crypto USDT**.
- **Polyglot Muse Translation:** Pengguna dari negara mana pun bebas mengetik *prompt* dalam bahasa ibu mereka (Inggris, Indonesia, Rusia, Arab, Jepang, Spanyol); Muse otomatis membalas dengan bahasa yang sama namun menerjemahkan instruksi render ke bahasa Inggris teknis untuk GPU.

BAGIAN IV: UI/UX SULTAN SUPER-APP, MODULAR GATEWAY, & PANEL SAKLAR 1 ANGKA

4.1 Smart Multimodal UX di Telegram (Sepintar Aplikasi Gemini/Qwen)

1. **Auto-Intent Detection (Tanpa Wajib Ketik /command):** Pengguna cukup mengetik kalimat biasa, mengirim foto, mengirim dokumen PDF/Word/Excel, atau mengirim *Voice Note* (diterjemahkan via *Whisper Free API* di Groq). Gatekeeper/Muse otomatis mendeteksi niat pengguna (CHAT, GENERATE_IMAGE, GENERATE_VIDEO, ORCHESTRATE_CAMPAIGN, READ_DOCUMENT, IMAGE_TO_VIDEO) dalam 0,5 detik.

2. **Inline Keyboard Kontekstual:** Di bawah setiap hasil gambar yang dikirim bot, otomatis muncul tombol lanjutan: [🎬 Gerakkan Jadi Video (20 Koin)], [🔍 Upscale 4K (4 Koin)], [📝 Buat Caption TikTok (Gratis)], [🔄 Variasi Baru].

4.2 Tampilan Menu "Sultan Super-App" & 3 Opsi Bio Powerful SEO (120 Karakter)

A. Pilihan Bio SEO Profil Bot (About Text Maksimal 120 Karakter)

- **Opsi 1 (Global & Indonesia — 116 Karakter):** ⚡ All-in-One AI Generator: Video (Kling/Wan/Veo), Flux HD Image, Suno Music & Copywriting. Free Daily Credits! 🎁🚀
- **Opsi 2 (Kata Kunci Pencarian Tinggi — 118 Karakter):** 🧠 Super AI Studio: Text/Image to Video, Motion Control, 4K Upscale, Suno Audio & Unfiltered AI. Claim Free Coins! ⚡
- **Opsi 3 (Fokus Kreator & Kampanye — 114 Karakter):** 🎬 #1 Autonomous AI Studio: Kling, Wan2.1, Flux, Suno & Auto-Campaigns in 1 Click. Free Daily Coins & Instant Pay!

B. Desain Kartu Menu Utama (/start — Gaya #1 Sultan Super-App)

🧠 **bikinAI Super Intelligence — All-in-One AI Studio**
——————————————— 👤 **Kreator:** @NamaUser *(Tier: Pro Member 🌟)* 💎
Koin Utama: 50 Koin (Rp 5.000) 🎁 **Koin Bonus:** 4 Koin (Rp 400) *(Klaim harian: Tersedia ✅)*
⚡ **Mesin Aktif:** Muse Orchestrator v2 + 9Router Turbo 🟢
——————————————— *Ketik perintah apa saja, kirim foto/PDF/suara langsung di chat ini, atau pilih Studio di bawah:*
[🚀 Buka Studio Visual & Klaim Harian (Mini App)] [🎬 Buat Video AI] [🎨 Buat Gambar HD] [🕺 Motion Control] [🎵 Musik & Suara (Suno)] [✨ Paket Kampanye Otomatis (Muse)] [🔍 Upscale 4K] [🎁 Klaim Koin Harian] [💳 Top-Up QRIS / Stars] [⚙️ Ganti Engine AI] [🎧 CS AI & Komunitas]

4.3 Kode Konfigurasi Panel Saklar 1 Angka (config.py)

Agar Anda tidak perlu menyewa GPU Vast.ai saat tahap pembangunan/pengujian dan bisa mengganti mesin atau tampilan dalam 0 detik tanpa mematikan bot yang sedang dipakai pelanggan:

```
#
# ============================================================================
# PANEL KENDALI CEPAT - BIKINAI SUPER INTELLIGENCE (config.py)
# Cukup ganti 1 digit angka [1], [2], atau [3] (Bisa diubah live via /admin)
#
# ============================================================================

# 1. PILIHAN MODE MESIN MEDIA (GAMBAR & VIDEO)
# [1] Mode Sandbox / Uji Coba Gratis Rp 0 (Pollinations + HF Free + Sample Video Cepat) -> PAKAI INI SAAT TESTING!
# [2] Mode API Grosir Pay-Per-Generate (Fal.ai / Replicate / Novita / PiAPI - Tanpa sewa GPU per jam)
```

```
# [3] Mode Pabrik GPU Mandiri (Vast.ai / RunPod 24GB VRAM ComfyUI
Serverless/Auto-Stop)
PILIHAN_MESIN_MEDIA = 1

# 2. PILIHAN OTAK UTAMA (MUSE / PROJECT MANAGER)
# [1] 9Router Localhost (Otomatis rotasi semua API gratis + 98% Quota
Surfing) -> REKOMENDASI UTAMA
# [2] Google Gemini 2.5 Flash (Langsung ke API Google AI Studio
Gratis)
# [3] Groq Cloud Super-Fast (Llama 3.3 70B Gratis - Kecepatan 0.2
detik)
# [4] OpenRouter Auto-Free (Otomatis pilih Qwen 2.5 / DeepSeek R1
berlabel :free)
# [5] Mode Darurat Lokal (Template pintar lokal jika seluruh koneksi
API luar gangguan)
PILIHAN_OTAK_MUSE = 1

# 3. PILIHAN OTAK KHUSUS JALUR UNFILTERED (HOROR / DEWASA / BEBAS
SENSOR)
# [1] Nous Hermes 3 Uncensored (via OpenRouter / Novita)
# [2] Qwen 2.5 72B Instruct (via 9Router / Groq)
# [3] Mistral Nemo Unfiltered
PILIHAN_OTAK_UNFILTERED = 1

# 4. PILIHAN GAYA TAMPILAN MENU TELEGRAM (UI/UX)
# [1] Gaya "Sultan Super-App" (Banner Video Animasi + Kartu Saldo +
Grid Lengkap)
# [2] Gaya "Minimalis Cepat" (Fokus ruang chat bersih ala
Gemini/ChatGPT)
# [3] Gaya "Kompetitor Pro" (Langsung daftar harga per model ala
PosMotion)
PILIHAN_TAMPILAN_MENU = 1
```

BAGIAN V: PERTAHANAN SIBER TINGKAT LANJUT (RED-TEAM vs. BLUE-TEAM) & ISOLASI HUKUM

Bagian ini mengunci seluruh celah keamanan tingkat produksi (*Production-Grade Edge Cases*), mulai dari pemindai internal Telegram, penyadapan server GPU, hingga 6 serangan eksploitasi siber pada arsitektur otonom.

5.1 Anatomi Pemblokiran Telegram & 4 Aturan Emas SOP Anti-Ban

Bot Telegram publik yang mengirim gambar/video 18+ (NSFW) atau kekerasan ekstrem secara langsung melalui pipa sendPhoto / sendVideo di ruang chat akan terdeteksi oleh **Automated Hash & NSFW Media Scanner** milik Telegram (demi kepatuhan Apple App Store & Google Play Store).

- **Aturan #1 (Hard-Lock Pipeline Isolation):** Bot Telegram Utama (@bikinAI_bot) **hanya diizinkan** mengirim media bertanda SFW_SAFE ke ruang chat. Seluruh konten *Unfiltered* wajib diisolasi ke arsitektur Web/Mini App terenkripsi.
- **Aturan #2 (Sistem Bot Kembar / Cold-Standby):** Seluruh database saldo koin disimpan di server eksternal kita (bukan di memori Telegram). Jika Bot #1 mengalami kendala, pergantian ke TOKEN_BOT_CADANGAN selesai dalam 10 detik tanpa kehilangan 1 koin pun.
- **Aturan #3 (has_spoiler=True & Teks Murni di Activity Bot):** Laporan di grup komunitas 📈 Activity Bot murni berupa teks status tanpa lampiran file media persis seperti strategi kompetitor.
- **Aturan #4 (Rate-Limiter / Anti-Flood):** Jeda otomatis 0,5–1 detik antar pesan ke pengguna yang sama untuk mencegah *auto-ban* anti-spam Telegram.

5.2 Matriks Audit 6-Lapisan Pertahanan Produksi (Zero-Knowledge & WebView Hardening)

Berdasarkan pemetaan arsitektur keamanan 6 tahapan (Tahap 1 s/d Tahap 6), berikut adalah mekanisme pertahanan yang ditanamkan ke dalam sistem kita dengan **biaya tambahan Rp 0**:

Kode & Tahap Pertahanan	Ancaman Fatal yang Dicegah	Mekanisme Teknis Pertahanan di Sistem Kita
Tahap 1: Gerbang Klien TMA (WebView) TMA-01, WV-02, WV-03	• Pemindaian *Crawler TelegramBot* yang memicu label *restricted* pada Bot (TMA-01). • Jejak forensik di *disk cache* HP Android (WV-02). • Kebocoran layar di *OS App Switcher / Recent Apps* (WV-03).	• **Zero-Trust Decoy Landing Page:** Jika URL diakses tanpa tanda tangan kriptografi Telegram.WebApp.initData yang valid (misalnya oleh *crawler* Telegram), halaman hanya merender web kalkulator/desain statis yang bersih. • **Auto-Blur & Biometric Lock:** Memasang pendengar visibilitychange & deactivated untuk menutup layar dengan *overlay* buram saat pengguna berpindah aplikasi, disertai kunci sidik jari/FaceID (BiometricManager) dan penyimpanan Blob murni di RAM.
Tahap 2: API Gateway & Auth API-01	• *Token Replay* & pencurian string initData lewat *Inspect Element (DevTools)* di Telegram Desktop untuk menembak API otomatis (API-01).	• **Verifikasi HMAC-SHA256 Ketat:** Memeriksa tanda tangan initData dengan batas kedaluwarsa auth_date maksimal **60 detik**, lalu menukarnya menjadi sesi **Short-Lived JWT** dengan *Rate Limiting* berbasis telegram_user_id.

Kode & Tahap Pertahanan	Ancaman Fatal yang Dicegah	Mekanisme Teknis Pertahanan di Sistem Kita
Tahap 3: Pre-Inference Guardrail AI-SEC-01, AI-SEC-02	• *Token Smuggling* / bahasa slang yang menembus filter kata biasa (AI-SEC-01). • Liabilitas hukum berat akibat pengguna mengunggah foto orang nyata/selebriti tanpa izin atau anak di bawah umur pada fitur *Img2Img / Image-to-Video* (AI-SEC-02).	• **Filter Multibahasa & Pre-Inference Vision Gate:** Memindai konteks semantik kalimat serta memasang pemeriksa wajah otomatis (**InsightFace Age/Gender Classifier + Hash Check**) di memori yang menolak otomatis foto wajah dengan estimasi usia di bawah **21–23 tahun** sebelum masuk ke antrean GPU.
Tahap 4: Antrean & Orkestrasi	• Tabrakan VRAM GPU saat pesanan membludak & kehilangan status (*state*) saat layar ditutup.	• **Persistent Async Queue:** Mengatur antrean secara asinkron dan menyimpan Job_ID secara terpisah dari mesin GPU untuk menjaga kontinuitas alur kerja.
Tahap 5: Stateless GPU Worker GPU-01	• Penyadapan model, log *prompt*, atau file gambar oleh pemilik fisik mesin (*host node*) di *marketplace* GPU seperti Vast.ai (GPU-01), serta output anatomi ilegal.	• **RAM-Only Processing (/dev/shm) & Negative Tensor:** Menyuntikkan *Negative Embedding Permanen* (anti-minor/anti-gore) langsung di level *tensor conditioning* GPU, memproses seluruh file murni di memori volatil /dev/shm (*tmpfs* berbasis RAM Linux) tanpa pernah menyentuh *hardisk* fisik, lalu langsung menghancurkannya (*zero-overwrite*) setelah dienkripsi dengan **AES-GCM**.
Tahap 6: Zero-Knowledge CDN INFRA-01, WV-01	• Pemindai otomatis Cloud/CDN (Cloudflare R2 / S3) yang men-*suspend* akun karena mendeteksi file .png/.mp4 dewasa (INFRA-01). • *Crash* layar putih di iPhone akibat batas memori *iOS WKWebView Jetsam RAM Limit* (WV-01).	• **Client-Side Encrypted Blob Delivery (.bin):** CDN hanya menyimpan dan mendistribusikan file biner terenkripsi (.bin) yang mustahil dipindai sensor cloud. Browser pengguna mendekripsinya langsung di RAM via **Web Crypto API (window.crypto.subtle)** menjadi Blob URL, dipadukan dengan **Virtual Scrolling**

Kode & Tahap Pertahanan	Ancaman Fatal yang Dicegah	Mekanisme Teknis Pertahanan di Sistem Kita
		(hanya merender 4–6 item di layar) dan URL.revokeObjectURL() otomatis agar iPhone tidak pernah *crash*.

5.3 Solusi Cerdas Atas Risiko Hukum & 5 Masalah Kritis Agregator (AGG-01 s/d AGG-05)

Sekadar memasang *checkbox* "Saya berusia 18+ dan untuk penggunaan pribadi" atau ancaman "Menuntut balik pengguna" tidak memberikan kekebalan hukum (*null and void* terhadap tindak pidana, menciptakan jebakan *Self-Incrimination*, dan tidak dibaca oleh robot moderator platform). Perlindungan sesungguhnya dicapai melalui **Safe Harbor via Technical Due Diligence** serta penutupan **5 Celah Agregator (AGG-01 s/d AGG-05)** dengan rekayasa cerdas berikut:

Identifikasi Masalah Agregator	Kelemahan Solusi Standar	Solusi Lebih Cerdas di bikinAI Super Intelligence
AGG-01 & AGG-02: Jebakan *Master API Key* Disita & Ilusi "Hanya Perantara" (Satu pembeli nakal membuat deposit API Rp 5 juta kita diblokir provider hulu).	Menolak *prompt* mentah dan menghanguskan saldo pembeli setelah 3x pelanggaran (memicu pembeli marah dan melaporkan rekening QRIS kita ke bank).	**1. Pre-Flight Guardrail di Rp 0:** Tolak mutlak CSAM/wajah anak/artis di gerbang lokal sebelum menyentuh Master API Key (modal terpakai Rp 0, akun di-*cooldown* tanpa merampas uang yang memicu laporan bank). **2. Muse Auto-Rewrite:** Untuk *prompt* yang sekadar nyerempet/kasar, Muse otomatis menulis ulang kalimatnya menjadi *prompt* fiksi dewasa (>25 tahun) yang sopan dan aman bagi API hulu.
AGG-03: Kebocoran Dapur Bisnis (*Inspect Element* URL asli), Link Mati 15 Menit, & Blokir ISP Indonesia (TrustPositif/Komdigi).	Menyuruh VPS backend mengunduh semua video dari engine pusat, menghapus EXIF dengan FFmpeg, lalu mengunggahnya ke R2 (membuat CPU & RAM VPS murah langsung 100% dan mati!).	**Cloudflare Workers Zero-VPS Edge Relay:** Jangan lewatkan file video ke VPS Bot! Gunakan *Cloudflare Workers* (gratis 100.000 request/hari) untuk menyedot file langsung dari URL engine hulu di jaringan *Edge* 10 Gbps, melucuti *header* metadata/EXIF secara *streaming*, mengenkripsinya ke .bin, dan menyimpannya ke R2. Beban VPS **0%**, dapur API tersembunyi rapat, dan bebas blokir ISP Indonesia tanpa VPN!

Identifikasi Masalah Agregator	Kelemahan Solusi Standar	Solusi Lebih Cerdas di bikinAI Super Intelligence
AGG-04: Risiko *Silent Censorship* (Provider A mendadak memperketat sensor dan menghasilkan gambar layar hitam / *black image*).	Coba render di Engine A dulu, kalau keluar gambar hitam/sensor baru lempar otomatis ke Engine B (membuat kita rugi bayar modal HPP **2 kali lipat** karena Engine A tetap memotong saldo saat keluar gambar hitam!).	**Pre-Flight Heat Router + 1ms Shannon Entropy Check:** Muse memberi skor panas (*Heat Score 0–100*) sebelum memanggil API. Jika skor >30, langsung arahkan sejak detik ke-0 ke mesin bebas sensor (enable_safety_checker: false) tanpa berjudi di Engine A! Ditambah pengecekan variasi piksel (*Shannon Entropy*) 0,001 detik di RAM untuk mendeteksi layar hitam.
AGG-05: Kebocoran Margin Akibat *HTTP Timeout* di Tengah Render (Saldo hulu terpotong, tapi koin user di-*refund*).	Menunggu respon sinkron atau langsung menganggap gagal saat koneksi terputus.	**Asynchronous Job_ID Reconciliation Polling:** Menyimpan provider_job_id ke database dan menanyakan ulang statusnya setiap 5 detik jika pipa HTTP terputus, sehingga video yang sudah terlanjur dirender di hulu tetap terambil dan dikirim ke pembeli.
Audit QRIS & Pelacakan Bukti (EXIF Stripping)	Menghapus seluruh EXIF tanpa sisa sehingga pemilik bot sendiri tidak tahu siapa user_id yang menyebarkan gambar ke luar.	**1. Decoupled SaaS Billing:** Transaksi QRIS dicatat murni sebagai pembelian *Kredit Komputasi Desain & Copywriting Produktivitas UMKM*. **2. Zero-EXIF Publik + Blind pHash Ledger (48 Jam):** File ke publik bersih 100% dari EXIF/PNG Info, namun server menyimpan sidik jari matematis 64-bit (*Perceptual Hash*) selama 48 jam khusus untuk audit internal Admin.

5.4 Peta Permukaan Serangan Siber Dual-Pipeline (SEC-01 s/d SEC-06) & Bukti Kode Pertahanan

Berdasarkan inspeksi *Red-Teaming* pada 6 titik arsitektur otonom (Node 1 s/d Node 6), berikut adalah perbandingan antara solusi teoretis yang boros memori dengan **Solusi Taktis Hemat RAM bikinAI Super Intelligence**:

Node & Vektor Serangan (Red Team)	Kelemahan Solusi Blue Team Standar di VPS Kecil	Solusi Taktis bikinAI Super Intelligence (Hemat RAM & Anti-Bobol)
Node 1 (SEC-02): *Financial*	Menyuruh pakai SELECT ...	**Per-User Asyncio Lock (64**

Node & Vektor Serangan (Red Team)	Kelemahan Solusi Blue Team Standar di VPS Kecil	Solusi Taktis bikinAI Super Intelligence (Hemat RAM & Anti-Bobol)
Race Condition (TOCTOU) — 50 request paralel dalam 1 milidetik menguras saldo API 20x lipat dengan modal 1 koin.	FOR UPDATE (tidak ada di SQLite!) atau memasang server Redis + Lua yang memakan ratusan MB RAM VPS.	**bytes RAM) + 1-Baris Atomic Conditional UPDATE ... RETURNING di SQLite WAL.** Saldo dipotong (*escrow*) di milidetik pertama sebelum menyentuh Router.
Node 1 (SEC-06): *Polyglot File Injection & Decompression Bomb* — File 500 KB meledak jadi 16 GB di RAM server.	Memeriksa di server setelah seluruh file selesai diunggah ke VPS.	**Client-Side <canvas> Re-encoding di HP Pembeli** (Menggambar ulang foto ke .webp maks 1280x1280 di browser HP pengguna sebelum diunggah—bom piksel & skrip ekor langsung hancur di HP penyerang!) + **24-Byte Header Guard (MAX_IMAGE_PIXELS)** di server.
Node 2 & 3 (SEC-01): *Semantic Router Poisoning / Polyglot Prompt* — Karakter U+200B atau metafora medis menipu Router sehingga *prompt* eksplisit nyasar ke API SFW dan membuat akun SFW diblokir.	Memasang model *CLIP Embedding* lokal di Router yang memakan >2 GB RAM VPS.	**NFKC Unicode Strip (unicodedata.normalize) + Zero-Passthrough Canonical Reconstruction:** Teks asli ketikan user **dilarang pernah** diteruskan mentah ke API gambar! Muse menulis ulang *prompt* dari nol, ditambah *Forced Negative Prompt* & safety_checker: true di Jalur A (SFW) dengan rotasi API Key gratis/saldo mikro ($1) via 9Router.
Node 4 (SEC-05): *Denial of Wallet (DoW)* — Parameter ganjil memicu *crash* di 95% komputasi dan *auto-retry* berantai membakar saldo di 3 engine.	Sekadar membatasi *retry* tanpa menyelamatkan komputasi yang sudah berjalan 90%.	**Two-Phase Circuit Breaker (3-Second Cut-Off):** Izinkan *auto-failover* ke Engine B **hanya jika gagal di bawah 3 detik** (*Pre-Flight/Queue Reject* = Rp 0 terpakai). Jika gagal di atas 3 detik (*Mid-Compute*), **0x Failover ke mesin lain**—langsung masuk ke Reconciliation Polling + **Preset Parameter Clamping** (pengguna hanya bisa klik tombol resolusi kelipatan 64).
Node 5 (SEC-03): *Webhook Spoofing & SSRF Media*	Sekadar memblokir daftar IP lokal di VPS (rawan ditembus	**Zero-VPS Fetching (Cloudflare Edge Fetcher) +**

Node & Vektor Serangan (Red Team)	Kelemahan Solusi Blue Team Standar di VPS Kecil	Solusi Taktis bikinAI Super Intelligence (Hemat RAM & Anti-Bobol)
Fetcher — Tembak *webhook* palsu untuk *auto-refund* koin atau curi metadata internal 169.254.169.254.	*DNS Rebinding*).	**Strict Domain Whitelist (ALLOWED_UPSTREAM_CDN) + HMAC Capability Token URL + One-Way refunded_lock di Database.** VPS tidak pernah mengunduh file dari URL luar!
Node 6 (SEC-04): *Side-Channel Timing & Domain Association* — Membongkar hubungan jalur SFW dan Unfiltered dari selisih waktu respon & domain yang sama.	Hanya menyeragamkan struktur JSON tanpa menyamakan waktu tunggu respon.	**Constant-Time 50ms Queue ACK** (Semua request di jalur mana pun langsung dibalas tiket antrean dalam 50ms yang seragam) + Pemisahan domain Kasir Utama dari domain *Ephemeral Edge Worker* pengirim .bin.

Bukti Kode Pertahanan Inti (Anti-TOCTOU, Anti-SSRF, & Two-Phase Circuit Breaker)

```
import asyncio
import hmac
import hashlib
import time
import unicodedata
from collections import defaultdict
from urllib.parse import urlparse
import aiosqlite

# 1. PERTAHANAN SEC-02: Zero-RAM Per-User Mutex + Atomic SQLite WAL
Escrow
USER_LOCKS = defaultdict(asyncio.Lock)

async def atomic_escrow_charge(db: aiosqlite.Connection, user_id: int,
cost: int, job_id: str) -> bool:
    """Menangkal 50 request paralel dalam 1 milidetik tanpa Redis."""
    async with USER_LOCKS[user_id]:
        cursor = await db.execute(
            """
            UPDATE users
            SET koin_utama = koin_utama - ?
            WHERE user_id = ? AND koin_utama >= ?
            RETURNING koin_utama;
            """,
            (cost, user_id, cost)
        )
```

```
        row = await cursor.fetchone()
        if not row:
            return False

        # Catat transaksi dengan pengunci refund satu arah
(refunded_lock = 0)
        await db.execute(
            """
            INSERT INTO jobs (job_id, user_id, cost, status,
refunded_lock, created_at)
            VALUES (?, ?, ?, 'PROCESSING', 0, ?)
            """,
            (job_id, user_id, cost, int(time.time()))
        )
        await db.commit()
        return True

# 2. PERTAHANAN SEC-01: Normalisasi Unicode NFKC & Penghapus Karakter
Hantu (U+200B)
def sanitize_polyglot_prompt(raw_text: str) -> str:
    normalized = unicodedata.normalize("NFKC", raw_text)
    clean_chars = [c for c in normalized if unicodedata.category(c)
not in ("Cf", "Cc", "Cs")]
    return "".join(clean_chars).strip()

# 3. PERTAHANAN SEC-03: Strict Hostname Whitelist (Anti-SSRF) & HMAC
Capability Token
ALLOWED_UPSTREAM_CDN = {"v3.fal.media", "fal.media",
"replicate.delivery", "cdn.bikinai-gpu.internal"}
SERVER_SECRET = b"GANTI_DENGAN_32_BYTE_KUNCI_RAHASIA_ANDA"

def verify_safe_upstream_url(url: str) -> bool:
    parsed = urlparse(url)
    return parsed.scheme == "https" and parsed.hostname in
ALLOWED_UPSTREAM_CDN

def generate_webhook_token(job_id: str) -> str:
    return hmac.new(SERVER_SECRET, job_id.encode(),
hashlib.sha256).hexdigest()

async def safe_one_time_refund(db: aiosqlite.Connection, job_id: str,
token: str) -> bool:
    """Menangkal Webhook Spoofing & Infinite Auto-Refund."""
    if not hmac.compare_digest(generate_webhook_token(job_id), token):
        return False
    cursor = await db.execute(
        """
        UPDATE jobs
```